

Cookie Session Collision Report

Audience

IT Infrastructure, Cyber Security, and Office of Information Management

Issue

Authorisations experienced session instability when another DBCA application set a cookie named `sessionid` on the parent domain `.dbca.wa.gov.au`.

On browsers that serialise duplicate cookies in a different order, Authorisations could receive the unrelated parent-domain session value last, causing:

- repeated session re-creation,
- authenticated pages to appear to work,
- API requests to fail with `403`,
- user form progress to stop saving reliably.

Scope

This issue affects any environment where:

- Authorisations is hosted on a subdomain such as `authorisations.dbca.wa.gov.au` or `authorisations-uat.dbca.wa.gov.au`, and
- another DBCA application writes a cookie named `sessionid` on `.dbca.wa.gov.au`.

Standards Findings

Research conclusion:

- The cookie behaviour is governed by IETF RFC 6265, not a W3C cookie-ordering standard.
- RFC 6265 states that servers should not rely on the serialisation order of cookies in the `Cookie` header.
- Therefore, browser differences in duplicate-cookie ordering are permitted behaviour.

Reference links:

- RFC 6265: <https://www.rfc-editor.org/rfc/rfc6265>
- W3C standards index: <https://www.w3.org/TR/>
- W3C web standards overview: <https://www.w3.org/standards/>

Root Cause

The root cause is a cookie-name collision across trust boundaries:

- Authorisations used the generic cookie name `sessionid`.
- A different DBCA application also used `sessionid` on a parent domain.

- When both cookies were present, browser ordering determined which value Django saw last.
- Django then accepted the last duplicate value, which could be the unrelated parent-domain cookie.

Immediate Remediation Completed

Authorisations now uses a unique session cookie name:

- `authorisations_sessionid`

It is also explicitly host-scoped:

- `SESSION_COOKIE_DOMAIN = None`

These changes are configured in the application settings and apply automatically across all environments.

Verification

Regression coverage was added to prevent recurrence. The application now includes tests that explicitly verify session stability when parent-domain cookies are present.

Operational Recommendations

Immediate (Completed)

- ✓ Authorisations now uses a distinct session cookie name to prevent collisions.

Short-term (Recommended)

1. Review other DBCA applications currently using generic cookie names (`sessionid`, `PHPSESSID`, etc.) on parent domains.
2. Audit the cookie scoping policy across the DBCA application estate for unrelated services.
3. Document which applications intentionally share session cookies via parent domains versus those that do not.

Long-term (Policy-driven)

Establish a DBCA-wide cookie naming and scoping policy:

- **Host-scoped by default:** Applications should use host-scoped session cookies (`Domain` attribute omitted or set to host only) unless there is an explicit, documented business requirement for cross-subdomain sharing.
- **Unique cookie names:** Application teams should adopt application-prefixed cookie names (e.g., `authorisations_sessionid`, `spms_sessionid`, `licensing_sessionid`) rather than reusing generic names (`sessionid`, `PHPSESSID`, etc.).
- **Deprecation plan:** For existing applications using generic parent-domain cookie names, establish a transition timeline and communicate it to development teams so they can migrate proactively.
- **Developer awareness:** Include cookie naming and domain scoping in onboarding

materials for new DBCA developers, and highlight the issue in architecture review checklists.

Residual Risk

Important caveat: This fix eliminates the specific collision with a sibling `sessionid` cookie on `.dbca.wa.gov.au`, but does not prevent future collisions if:

- Another application chooses to use `authorisations_sessionid` on the parent domain, or
- Another application sets a different cookie on the parent domain that Authorisations later needs to consume.

There is no "perfect fix" for cross-subdomain cookie collisions at the application level. The only way to eliminate this class of risk organisation-wide is to:

1. Establish and enforce a cookie naming policy,
2. Centralise or document cookie scoping decisions,
3. Raise developer awareness so teams do not accidentally reintroduce similar collisions,
4. Treat host-scoped isolation as the default posture for authentication cookies.